# Network Security — 150 MCQ Question Bank

Third Stage | Lectures: Week 1, Weeks 2 & 3, Firewalls (up to DMZ)

*The correct answer is highlighted in yellow.* Example

## Part 1 — Easy (Q1–Q50)

**Q1. A computer network connects devices so that they can:**

**A)** Block all external access
**B)** Store data only on one device
**C)** Increase each device's processing power
**D)** **Exchange data and share services**
**E)** Work without any protocols

**Q2. Which device connects devices within a local network?**

**A)** Firewall
**B)** Router
**C)** Scanner
**D)** Modem
**E)** **Switch**

**Q3. Which device connects different networks together?**

**A)** Switch
**B)** **Router**
**C)** Printer
**D)** Repeater
**E)** Hub

**Q4. A computer laboratory in one building is an example of a:**

**A)** PAN
**B)** WAN
**C)** **LAN**
**D)** MAN
**E)** VPN

**Q5. A phone connected to its wearable forms a:**

**A)** **PAN**
**B)** LAN
**C)** WAN
**D)** MAN
**E)** SAN

**Q6. University branches in Baghdad and Basra connected together form a:**

**A)** PAN
**B)** MAN
**C)** SAN
**D)** LAN
**E)** **WAN**

**Q7. In which topology do all devices connect to a central device?**

**A)** Mesh
**B)** Ring
**C)** **Star**
**D)** Bus
**E)** Tree

**Q8. In which topology do the connections form a loop?**

**A)** **Ring**
**B)** Star
**C)** Mesh
**D)** Tree
**E)** Bus

**Q9. In which topology do several paths connect the devices?**

**A)** Ring
**B)** Star
**C)** Bus
**D)** **Mesh**
**E)** Point-to-point

**Q10. In which topology do devices share a single backbone connection?**

**A)** Ring
**B)** **Bus**
**C)** Mesh
**D)** Star
**E)** Tree

**Q11. A protocol is best defined as:**

**A)** A physical medium that carries signals
**B)** An address that identifies a host
**C)** **An agreed set of communication rules**
**D)** A device that forwards packets
**E)** A unit of data sent on a link

**Q12. A port is:**

**A)** An address identifying a whole network
**B)** **A number identifying a service on a host**
**C)** A secret key used to encrypt network traffic
**D)** A device connecting two networks
**E)** A unit of data carried in a frame

**Q13. A packet is:**

**A)** **A unit of data sent across a network**
**B)** A weakness in a network service
**C)** A number identifying a service
**D)** A device that forwards traffic
**E)** A set of rules that governs communication

**Q14. Something valuable to the organization that needs protection is called a(n):**

**A)** Exploit
**B)** Threat
**C)** Attack
**D)** Vulnerability
**E)** **Asset**

**Q15. Locking the server room is an example of which control type?**

**A)** Administrative
**B)** Detective
**C)** Technical
**D)** **Physical**
**E)** Logical

**Q16.** **Staff security training is an example of which control type?**

**A)** Physical
**B)** Environmental
**C)** **Administrative**
**D)** Cryptographic
**E)** Technical

**Q17.** **A firewall rule is an example of which control type?**

**A)** **Technical**
**B)** Environmental
**C)** Managerial
**D)** Administrative
**E)** Physical

**Q18.** **"Only permitted readers see the information" describes:**

**A)** Non-repudiation
**B)** **Confidentiality**
**C)** Availability
**D)** Integrity
**E)** Accountability

**Q19.** **A student's mark is changed from 82 to 28 without approval. Which goal failed?**

**A)** Availability
**B)** Authenticity
**C)** Accountability
**D)** Confidentiality
**E)** **Integrity**

**Q20.** **The university portal does not open when registration begins. Which goal failed?**

**A)** Authenticity
**B)** Accountability
**C)** Confidentiality
**D)** **Availability**
**E)** Integrity

**Q21.** **Authentication answers the question:**

**A)** May you perform this action?
**B)** Has the data been changed?
**C)** Which port does the service use?
**D)** **Are you who you claim to be?**
**E)** Is the service available now?

**Q22.** **Authorization answers the question:**

**A)** Are you who you claim to be?
**B)** Has the data been changed?
**C)** Which port does the service use?
**D)** Is the service available now?
**E)** **May you perform this action?**

**Q23.** **Least privilege means:**

**A)** **Giving only the access needed for a task**
**B)** Granting rights based on seniority
**C)** Removing all access after each login
**D)** Giving every user the same full access
**E)** Giving access only during official work hours

**Q24. Encryption:**

- **A)** Turns a domain name into the matching IP address
- **B)** **Turns plaintext into ciphertext with a key**
- **C)** Turns a private address into a public one
- **D)** Turns a packet into a link-layer frame
- **E)** Turns ciphertext into a MAC address

**Q25. What does an IDS do?**

- **A)** Assigns addresses to new clients
- **B)** Blocks malicious packets inline
- **C)** **Observes activity and raises alerts**
- **D)** Translates domain names into IP addresses
- **E)** Translates domain names to IPs

**Q26. The three functions of network security in the lecture are:**

- **A)** Encryption, hashing and signing
- **B)** Scanning, sniffing and spoofing
- **C)** **Protection, detection and response**
- **D)** Planning, configuring and deploying
- **E)** Routing, switching and bridging

**Q27. A vulnerability is:**

- **A)** A deliberate attempt to cause harm
- **B)** A valuable resource to protect
- **C)** A measure that reduces harm
- **D)** A technique for using a weakness
- **E)** **A weakness that may allow harm**

**Q28. A threat is:**

- **A)** **A possible cause of harm**
- **B)** A confirmed incident
- **C)** A weakness in a system or process
- **D)** A valuable resource
- **E)** A protection measure

**Q29. How many layers does the OSI model have?**

- **A)** 8
- **B)** 4
- **C)** 6
- **D)** **7**
- **E)** 5

**Q30. The TCP/IP model commonly groups network functions into how many layers?**

- **A)** 6
- **B)** **4**
- **C)** 3
- **D)** 5
- **E)** 7

**Q31. ARP maps:**

- **A)** A port number to a service name
- **B)** A domain name to an IPv4 address
- **C)** A private address to a public one
- **D)** A MAC address to a switch port
- **E)** **An IPv4 address to a MAC address**

**Q32. Which protocol supplies an IP lease, default gateway and DNS resolver addresses?**

- **A)** **DHCP**
- **B)** NAT
- **C)** ICMP
- **D)** DNS
- **E)** ARP

**Q33. DNS translates:**

- **A)** Port numbers into application names
- **B)** User names into access permissions
- **C)** IPv4 addresses into MAC addresses
- **D)** **Domain names into resource records**
- **E)** Private addresses into public ones

**Q34. TCP and UDP port numbers range from:**

- **A)** 1 to 32767
- **B)** 1 to 255
- **C)** **0 to 65535**
- **D)** 0 to 1023
- **E)** 0 to 4095

**Q35. The ping tool commonly uses:**

- **A)** UDP queries sent to DNS port 53
- **B)** **ICMP Echo Request and Reply**
- **C)** TCP SYN and SYN+ACK
- **D)** ARP request and reply
- **E)** DHCP Discover and Offer

**Q36. HTTPS is:**

- **A)** HTTP carried over UDP
- **B)** **HTTP protected with TLS**
- **C)** HTTP protected with DHCP
- **D)** HTTP protected with ARP
- **E)** HTTP carried inside ICMP

**Q37. Sniffing means:**

- **A)** Flooding a server with SYN packets
- **B)** Exhausting a DHCP pool
- **C)** Forging the source address
- **D)** **Capturing and examining packets**
- **E)** Changing cookie contents

**Q38. Spoofing means:**

- **A)** **Presenting false identity information**
- **B)** Scanning the open ports of a host
- **C)** Writing past a buffer's boundary
- **D)** Overloading a switch's MAC address table
- **E)** Capturing packets on a shared link

**Q39. A firewall filters packets according to:**

- **A)** The brand of the operating system
- **B)** The order in which devices were installed
- **C)** The speed of each user's connection
- **D)** The physical length of network cables
- **E)** **Rules derived from the security policy**

**Q40. Which firewall policy do security professionals recommend?**

**A)** Deny only Telnet
**B)** Allow all outbound
**C)** **Default deny**
**D)** Default allow
**E)** Allow all inbound

**Q41. Which is an example of a host-based firewall?**

**A)** Fortinet FortiGate
**B)** Cisco ASA security appliance
**C)** pfSense edge device
**D)** **Windows Defender Firewall**
**E)** Snort network sensor

**Q42. A firewall separates:**

**A)** **A trusted network from an untrusted one**
**B)** A laptop from a shared printer
**C)** A DNS server from a DHCP server
**D)** A web server from its back-end database server
**E)** A switch from its directly connected router

**Q43. When a firewall denies a packet, it:**

**A)** Changes its source address
**B)** **Drops it and logs the event**
**C)** Encrypts it and forwards it
**D)** Forwards it to the internal LAN
**E)** Returns it to the core switch

**Q44. ACL stands for:**

**A)** Application Control Layer
**B)** Access Credential Lock
**C)** Allowed Connection Link
**D)** Address Configuration Log
**E)** **Access Control List**

**Q45. MAC address filtering is a firewall service at which layer?**

**A)** Application
**B)** Network
**C)** **Data link**
**D)** Physical
**E)** Transport

**Q46. IP address filtering and NAT are firewall services at which layer?**

**A)** Data link
**B)** Session
**C)** Physical
**D)** Transport
**E)** **Network**

**Q47. A SOHO firewall is typically used in:**

**A)** Cloud provider cores
**B)** Large enterprise data centers
**C)** ISP backbone links
**D)** **Homes and small offices**
**E)** Military networks

**Q48. The APNIC slide describes a man-in-the-middle attack as:**

**A)** Passive traffic scanning
**B)** Address leasing
**C)** **Active eavesdropping**
**D)** Physical theft
**E)** Memory corruption

**Q49. Reconnaissance means:**

**A)** Blocking unused ports on a firewall
**B)** **Collecting information about a target**
**C)** Restoring a service after an attack
**D)** Encrypting all traffic between two sites
**E)** Assigning IP leases to new hosts

**Q50. Which tool is an example of a network-based firewall product?**

**A)** **Cisco ASA**
**B)** A browser extension
**C)** Windows Defender Firewall
**D)** Linux iptables on a laptop
**E)** An antivirus scanner

## Part 2 — Medium (Q51–Q100)

**Q51. The correct order of the TCP three-way handshake is:**

**A)** SYN → ACK → SYN+ACK
**B)** ACK → SYN → SYN+ACK
**C)** **SYN → SYN+ACK → ACK**
**D)** SYN → FIN → ACK
**E)** SYN+ACK → SYN → ACK

**Q52. The common initial IPv4 DHCP exchange is:**

**A)** **Discover, Offer, Request, Ack**
**B)** Request, Offer, Discover, Ack
**C)** Offer, Discover, Ack, Request
**D)** Request, Discover, Ack, Offer
**E)** Discover, Request, Offer, Ack

**Q53. IPv6 uses _____ instead of ARP.**

**A)** DHCP address leasing
**B)** **Neighbor Discovery**
**C)** Router Advertisement only
**D)** ICMP Echo Request
**E)** Reverse DNS lookup

**Q54. What is a key difference between UDP and TCP?**

**A)** UDP encrypts data while TCP leaves it plain
**B)** UDP authenticates each sender before sending
**C)** UDP uses 32-bit port numbers instead of 16-bit
**D)** UDP guarantees in-order delivery of data
**E)** **UDP has no connection setup or retransmission**

**Q55. Which statement about TCP is correct?**

**A)** It encrypts all application data it carries by default
**B)** It delivers data without any acknowledgments
**C)** It authenticates the remote user before sending data
**D)** **It is reliable but neither encrypts nor authenticates**
**E)** It works without keeping any connection state

**Q56. A passive attack mainly:**

**A)** Injects forged packets into a flow
**B)** Floods a link to block the service
**C)** Alters records stored in a database
**D)** **Observes traffic without changing it**
**E)** Redirects traffic toward a fake server

**Q57. Port scanning is normally considered:**

**A)** Passive reconnaissance
**B)** **Active reconnaissance**
**C)** Cookie poisoning
**D)** Session hijacking
**E)** Passive sniffing

**Q58. Masquerading means:**

**A)** Destroying stored data
**B)** Exceeding permitted rights
**C)** **Claiming another identity**
**D)** Flooding a network link
**E)** Denying a past action

**Q59. Repudiation concerns:**

**A)** Overloading a service with requests
**B)** Claiming the identity of another user
**C)** Using rights beyond those permitted
**D)** Reading unprotected network traffic
**E)** **Denying participation in an action**

**Q60. An authorization violation means:**

**A)** **Using a resource beyond permitted rights**
**B)** Denying an action that was performed
**C)** Observing unprotected network traffic
**D)** Sending forged ARP replies on a LAN
**E)** Claiming to be a different legitimate user

**Q61. According to the APNIC slide, a MITM attack usually results from a lack of:**

**A)** Available link bandwidth
**B)** Working DHCP servers
**C)** **End-to-end authentication**
**D)** Redundant network paths and links
**E)** Free IP address space

**Q62. In session hijacking, the attacker:**

**A)** Spoofs the gateway's MAC address
**B)** Exhausts the DHCP address pool
**C)** Floods a server with SYN packets
**D)** Overloads the switch's CAM table
**E)** **Reuses a stolen session token**

**Q63. Which measures protect against session hijacking?**

**A)** DHCP snooping and IP leasing
**B)** Larger buffers and stack canaries
**C)** Port security and VLAN pruning rules
**D)** **TLS, secure cookies, token rotation**
**E)** Disabling directed broadcasts

**Q64. A MAC flooding attack targets:**

**A)** **The switch's MAC-to-port table**
**B)** The resolver's cache of DNS answers
**C)** The router's routing table
**D)** The server's DHCP lease pool
**E)** The host's IP-to-MAC cache

**Q65. The primary mitigation for MAC flooding is:**

**A)** Disabling ICMP echo replies
**B)** **Port security on switch ports**
**C)** Longer DHCP lease durations
**D)** TLS with full certificate validation
**E)** Output encoding on web pages

**Q66. The classical Smurf attack is limited in modern networks by:**

**A)** Adding CSRF tokens to web forms
**B)** Using longer TCP session timeouts
**C)** **Disabling IP-directed broadcast**
**D)** Increasing the DHCP pool size
**E)** Enabling port security on switches

**Q67. The historical Smurf attack works by sending:**

**A)** **A forged echo to a broadcast address**
**B)** Many frames with random source MACs
**C)** Many SYNs without the final ACK segment
**D)** Oversized input to a server's buffer
**E)** A forged ARP reply sent to the default gateway

**Q68. A buffer overflow occurs when a program:**

**A)** Caches a forged answer from a resolver
**B)** **Writes beyond a buffer's intended bounds**
**C)** Learns too many MAC addresses at once
**D)** Reuses a stolen session token silently
**E)** Accepts a request from a logged-in browser

**Q69. Which defenses mainly address XSS?**

**A)** TLS and token rotation
**B)** CSRF tokens and SameSite
**C)** Port security and VLANs
**D)** DHCP snooping and ACLs
**E)** **Output encoding and CSP**

**Q70. Which defenses mainly address CSRF?**

**A)** Port security and VLAN rules
**B)** Output encoding and CSP
**C)** Stack canaries and ASLR
**D)** **CSRF tokens and SameSite**
**E)** DHCP snooping and ACLs

**Q71. Cross-site scripting (XSS) is best described as:**

**A)** Oversized input overwriting adjacent memory
**B)** An attacker reusing a stolen session token
**C)** A logged-in browser sending an unwanted request
**D)** A server trusting a modified hidden field
**E)** **Untrusted script running in the user's browser**

**Q72. Cross-site request forgery (CSRF) is best described as:**

**A)** An attacker reusing a stolen session token
**B)** A server trusting a modified hidden form value
**C)** Untrusted script running in the user's browser
**D)** **A logged-in browser sending an unwanted request**
**E)** Oversized input overwriting adjacent memory

**Q73. Risk is commonly assessed using:**

**A)** Ports and protocols
**B)** Bandwidth and latency
**C)** **Likelihood and impact**
**D)** Users and roles
**E)** Speed and cost

**Q74. Which list contains the risk treatment options?**

**A)** **Reduce, avoid, transfer, accept**
**B)** Scan, sniff, spoof, flood
**C)** Detect, deny, delay, deter
**D)** Identify, protect, detect, recover
**E)** Plan, test, deploy, manage

**Q75. Risk that remains after protection is applied is called:**

**A)** Inherent risk
**B)** **Residual risk**
**C)** Accepted risk
**D)** Transferred risk
**E)** Zero-day risk

**Q76. Multi-factor authentication combines:**

**A)** **Factors from different categories**
**B)** A username and an IP address
**C)** Two different passwords for one account
**D)** Two logins on the same device
**E)** One password checked twice

**Q77. Defence in depth means:**

**A)** Replacing technical controls with training
**B)** Placing all servers in a single segment
**C)** Allowing all traffic but logging all of it
**D)** **Layering controls so one failure is not fatal**
**E)** Relying on one strong firewall at the perimeter

**Q78. Which is a firewall design goal?**

**A)** Only inbound traffic needs to be checked
**B)** **All traffic must pass through the firewall**
**C)** Trusted users may bypass the firewall
**D)** The firewall should run many extra services
**E)** The firewall should use default allow

**Q79. A bastion host is:**

**A)** A sensor copying traffic to an IDS
**B)** A switch connecting all internal hosts
**C)** A server assigning IP addresses to hosts
**D)** A normal workstation serving internal staff
**E)** **A hardened host acting as the choke point**

**Q80. How does a packet-filtering firewall process its ACL?**

**A)** The most specific match decides
**B)** The newest rule always decides
**C)** **Top-down; the first match decides**
**D)** Bottom-up; the last match decides
**E)** All matching rules are combined

**Q81. In TCP ACK-bit filtering, a packet with ACK = 0 is:**

**A)** A connection being closed
**B)** A retransmitted segment
**C)** A reply in an open connection
**D)** An ICMP error message
**E)** **A new connection request**

**Q82. An inbound packet from the Internet carrying an internal source address indicates:**

**A)** NAT translation
**B)** A DHCP offer
**C)** VPN encapsulation
**D)** **IP spoofing**
**E)** A normal reply

**Q83. A stateful firewall records connections in a:**

**A)** DNS cache
**B)** ARP cache
**C)** **State table**
**D)** Routing table
**E)** CAM table

**Q84. An application-level gateway (proxy firewall):**

**A)** **Terminates one connection and opens another**
**B)** Copies all traffic to an IDS sensor
**C)** Filters traffic only on MAC addresses
**D)** Relays sessions without inspecting data
**E)** Forwards packets without reading their data

**Q85. A WAF using the positive security model:**

**A)** Allows requests from trusted subnets
**B)** **Allows only known-good requests**
**C)** Allows all except blacklisted IPs
**D)** Blocks only known attack signatures
**E)** Blocks requests on unusual ports

**Q86. A WAF using the negative security model:**

**A)** **Blocks known attack signatures**
**B)** Allows only whitelisted users
**C)** Blocks every encrypted request
**D)** Allows only known-good requests
**E)** Blocks all requests by default

**Q87. A circuit-level gateway works at which OSI layer?**

**A)** Layer 3 (Network)
**B)** Layer 2 (Data link)
**C)** **Layer 5 (Session)**
**D)** Layer 4 (Transport)
**E)** Layer 7 (Application)

**Q88. SOCKS is the best-known example of a:**

**A)** Stateful inspection firewall
**B)** Stateless packet filter
**C)** NAT-based firewall
**D)** **Circuit-level gateway**
**E)** Web application firewall

**Q89. Which feature belongs to a Next-Generation Firewall?**

**A)** A default allow policy for all apps
**B)** **Application awareness regardless of port**
**C)** Filtering traffic based only on MAC addresses
**D)** Inspection of physical-layer signals
**E)** Stateless filtering of headers only

**Q90. What is the difference between "drop" and "reject"?**

**A)** Drop is stateful; reject is stateless
**B)** Drop informs the sender; reject is silent
**C)** Drop is inbound; reject is outbound
**D)** Drop logs the packet; reject never does
**E)** **Drop is silent; reject informs the sender**

**Q91. Which is an advantage of a stateless packet filter?**

**A)** Remembers earlier packets in a table
**B)** Resists IP spoofing and fragmentation
**C)** **Fast, cheap and transparent to users**
**D)** Inspects the full payload of packets
**E)** Easy to manage with huge rule sets

**Q92. Which is a disadvantage of a stateless packet filter?**

**A)** It needs a client on every host
**B)** It is too expensive to put on routers
**C)** It is not transparent to the users
**D)** It is too slow to work at line speed
**E)** **It cannot inspect the packet payload**

**Q93. At which OSI layers does a stateless packet filter operate?**

**A)** 5 only
**B)** 2–7
**C)** 2 only
**D)** **3–4**
**E)** 7 only

**Q94. At which OSI layers does a Next-Generation Firewall operate?**

**A)** **2–7**
**B)** 1–2
**C)** 5 only
**D)** 3–4
**E)** 7 only

**Q95. According to the comparison table, an application proxy / WAF has:**

**A)** Low security, slow speed
**B)** **High security, slow speed**
**C)** Medium security, fast speed
**D)** Very high security, medium speed
**E)** Low security, very fast speed

**Q96. "Host IP address hiding" in a proxy firewall means:**

**A)** **Outside sniffers see only the proxy's IP**
**B)** The proxy removes IPs from its own logs
**C)** Outside servers see the client's real IP
**D)** The proxy assigns random IPs to clients
**E)** Internal hosts cannot see each other's IPs

**Q97. A NAT firewall accepts inbound packets only if they:**

**A)** Carry the ACK bit set to zero
**B)** Come from a private source address
**C)** Use a port number below 1024
**D)** **Match an earlier outgoing request**
**E)** Arrive from a trusted DNS server

**Q98. Which rule-writing best practice protects against spoofing?**

**A)** Allow inbound packets with private sources
**B)** Allow all ICMP arriving from outside
**C)** Log only the traffic that is allowed
**D)** Drop outbound packets to public hosts
**E)** **Drop inbound packets with private sources**

**Q99. Why should a firewall also filter outbound traffic?**

**A)** To speed up staff web browsing
**B)** To reduce the total number of firewall rules
**C)** **So infected hosts cannot reach attackers**
**D)** To hide internal IP addresses
**E)** To allow inbound replies automatically

**Q100. Which action reduces exposure to reconnaissance?**

**A)** Open all ports so scanners are detected early
**B)** **Remove unneeded services, restrict admin access**
**C)** Disable logging to reduce monitoring noise
**D)** Use one flat network for better visibility
**E)** Publish detailed operational network diagrams online

## Part 3 — Hard (Q101–Q150)

**Q101. On a switched Ethernet network, putting a NIC into promiscuous mode:**

**A)** Automatically poisons the ARP caches of hosts
**B)** **Does not by itself expose unrelated switch traffic**
**C)** Decrypts TLS traffic passing through the switch
**D)** Exposes every unicast frame from all of the switch ports
**E)** Clears the switch MAC table to force flooding

**Q102. Which statement correctly distinguishes ARP poisoning from MAC flooding?**

**A)** **ARP poisoning alters a host map; MAC flooding fills a switch table**
**B)** Both alter the routing table kept on the default gateway
**C)** Both alter the same forwarding table inside the same switch
**D)** ARP poisoning targets DNS caches; MAC flooding targets DHCP
**E)** ARP poisoning fills a switch table; MAC flooding alters a host map

**Q103. According to the lecture, which statement about MAC flooding is INACCURATE?**

**A)** Encryption still protects correctly secured sessions
**B)** Outcome depends on hardware, software and configuration
**C)** Unknown unicast traffic may be flooded within the relevant VLAN
**D)** The scope remains constrained by VLAN membership
**E)** **Every affected switch simply becomes an unrestricted hub**

**Q104. DHCP and DNS belong to which layer, even though their misuse disrupts network operation?**

**A)** Transport
**B)** Presentation
**C)** Data link
**D)** **Application**
**E)** Network

**Q105. According to the lecture, routing attacks belong to the:**

**A)** Presentation layer
**B)** Physical signalling layer
**C)** **Network control plane**
**D)** Transport layer
**E)** Data link layer

**Q106. A SYN flood makes an application unavailable by exploiting:**

**A)** Host acceptance of unsolicited ARP replies
**B)** **Server handling of incomplete TCP connections**
**C)** Switch learning of source MAC addresses
**D)** Client trust in unsigned answers from DNS servers
**E)** Browser trust in authenticated sessions

**Q107. An attacker forges a source IP address. What is true?**

**A)** The attacker always controls the return path
**B)** TLS sessions to the forged host always break
**C)** The attacker gains the forged host's privileges
**D)** **Replies go to the forged host, not the attacker**
**E)** The firewall must accept the forged packet

**Q108. A user sends an unauthorized request over a perfectly encrypted connection. What is true?**

**A)** TLS rejects the request before it arrives
**B)** The transport layer drops such requests
**C)** Encryption performs the authorization check
**D)** The firewall blocks any unauthorized request type
**E)** **The server must still check permission itself**

**Q109. Regarding a record ID in a URL, which statement is correct?**

**A)** **The ID is fine; the flaw is a missing access check**
**B)** Checking the ID in the browser is sufficient
**C)** Hiding the admin link fully protects the endpoint
**D)** Any record ID shown in a URL is itself a vulnerability
**E)** Signing the ID removes the need for checks

**Q110. Signed data in a cookie or parameter:**

**A)** Prevents XSS in every page that uses the value
**B)** Replaces all server-side authorization checks
**C)** **Detects tampering but does not replace authorization**
**D)** Hides the value completely from the user's web browser
**E)** Makes client-supplied prices fully authoritative

**Q111. Stack protection, non-executable memory and ASLR:**

**A)** **Make exploitation harder but don't fix the flaw**
**B)** Guarantee a crash never becomes exploitable
**C)** Replace the need for input length validation
**D)** Remove the buffer overflow bug from the program code
**E)** Block malicious input at the network layer

**Q112. If traffic is protected by correctly authenticated encryption, a sniffer generally sees:**

**A)** Nothing at all, not even IP addresses
**B)** Only the user's login credentials
**C)** Full application content in plaintext
**D)** The session keys used by both ends
**E)** **Encrypted payload and some metadata**

**Q113. Missing ping (ICMP) replies:**

**A)** Prove that the route is broken
**B)** **Do not alone prove the host is down**
**C)** Prove that ICMP is not supported
**D)** Prove that the host is compromised
**E)** Prove that the host is powered off completely

**Q114. Which statement about SSL version 3 is correct?**

**A)** Deprecated only for email, not for web
**B)** Replaced by SSL version 4 in 2015
**C)** Required for HTTPS in modern browsers
**D)** **Formally deprecated; not a modern choice**
**E)** The current recommended version of TLS for HTTPS

**Q115. Why is source-address spoofing especially relevant to UDP reflection attacks?**

**A)** UDP is always blocked by stateful firewalls
**B)** UDP replies are never larger than requests
**C)** **No handshake confirms the source address**
**D)** UDP packets carry no source port field
**E)** UDP requires broadcast destination addresses

**Q116. Which of the following is a threat but NOT an attack?**

**A)** **A power failure**
**B)** A SYN flood
**C)** Password guessing
**D)** ARP spoofing
**E)** SQL injection

**Q117. A university exposes a remote admin service with a weak password. Which item is the vulnerability?**

**A)** Unauthorized login
**B)** **The weak password**
**C)** Password guessing
**D)** Stolen records
**E)** The exposed server

**Q118. In the same example, "password guessing" is the:**

**A)** Exposed weakness
**B)** Vulnerability
**C)** **Attack technique**
**D)** Asset
**E)** Threat scenario

**Q119. In the same example, "unauthorized login" is the:**

**A)** Asset
**B)** Vulnerability
**C)** Countermeasure
**D)** **Threat scenario**
**E)** Residual weakness

**Q120. A student role has unnecessary permission to edit grades. This is a(n):**

**A)** Attack
**B)** Valuable asset
**C)** Threat
**D)** Security control
**E)** **Vulnerability**

**Q121. An attacker copies records and then deletes them. Which goals are affected?**

**A)** Integrity only, because the records were altered
**B)** Availability only, because the data has now been deleted
**C)** Confidentiality only, because the data was read
**D)** **Confidentiality, integrity and maybe availability**
**E)** None of them, if the service stays online

**Q122. A student logs in successfully but is refused permission to change a grade. This is:**

**A)** Faulty: a login should allow every action
**B)** Faulty: MFA must be misconfigured for this account
**C)** Correct: the firewall blocked the request
**D)** Faulty: the portal must be unavailable
**E)** **Correct: authentication is not authorization**

**Q123. A rule "Allow Any Any" is placed at the top of the ACL. What is the effect?**

**A)** It applies only if no rule matches
**B)** It applies only to outbound traffic
**C)** **It shadows every rule beneath it**
**D)** It is skipped since deny rules win
**E)** It is overridden by the default deny

**Q124. Using the lecture's rule table, a TCP packet to 198.124.1.10 on port 22 is:**

**A)** **Denied by rule 4 (default)**
**B)** Allowed as a public server
**C)** Allowed by rule 2 (HTTPS)
**D)** Allowed by rule 1 (HTTP)
**E)** Denied by rule 3 (Telnet)

**Q125. Using the lecture's rule table, a TCP packet to 198.124.1.10 on port 443 is:**

**A)** Denied by rule 3 (Telnet)
**B)** **Allowed by rule 2 (HTTPS)**
**C)** Allowed by rule 1 (HTTP)
**D)** Denied by rule 4 (default)
**E)** Allowed by rule 4 (default)

**Q126. Why is UDP hard to filter safely with a stateless packet filter?**

**A)** No port numbers to filter different services by
**B)** **No ACK bit to tell replies from new flows**
**C)** Always carried inside ICMP messages
**D)** Too fast for routers to inspect it
**E)** Always encrypted, hiding all its headers

**Q127. A stateful firewall receives a packet with ACK = 1 that matches no state-table entry. It is:**

**A)** **Dropped, as it matches no connection**
**B)** Allowed if the port is 80 or 443
**C)** Forwarded to a proxy for checking
**D)** Added to the table as ESTABLISHED
**E)** Allowed, because its ACK flag is set to 1

**Q128. Which proxy protection stops an attacker tunneling another protocol through an allowed port?**

**A)** Header destruction
**B)** Host IP address hiding
**C)** **Protocol enforcement**
**D)** ACK-bit filtering
**E)** Address translation

**Q129. "Header destruction" in a proxy firewall means the proxy:**

**A)** Copies headers to an IDS sensor
**B)** Deletes headers from its log files
**C)** Strips encryption from the payload
**D)** Removes only the MAC header
**E)** **Rebuilds new TCP/UDP/IP headers**

**Q130. The main weakness of the dual-homed host architecture is:**

**A)** Router compromise can bypass the bastion host
**B)** It routes freely between its two NICs
**C)** It is more complex and costly to run
**D)** **If it is compromised, the LAN is exposed**
**E)** It cannot host any proxy services

**Q131. The main weakness of the screened host architecture is:**

**A)** If the dual-homed host falls, LAN is exposed
**B)** **Router compromise can bypass the bastion**
**C)** It cannot filter any inbound packets
**D)** It routes freely between its two NICs
**E)** It provides only one weak layer of defence

**Q132. The main weakness of the screening router architecture is:**

**A)** If the host falls, the LAN is exposed
**B)** It needs two NICs with routing disabled
**C)** It is more complex and costly to run
**D)** **It is only one weak layer of defence**
**E)** Router compromise bypasses the bastion

**Q133. The correct order of the NIST SP 800-41 firewall implementation cycle is:**

**A)** **Plan → Configure → Test → Deploy → Manage**
**B)** Plan → Configure → Deploy → Test → Manage
**C)** Plan → Deploy → Configure → Test → Manage
**D)** Configure → Plan → Test → Deploy → Manage
**E)** Plan → Test → Configure → Deploy → Manage

**Q134. In the NIST cycle, what happens in the "Test" step?**

**A)** The firewall is hardened and logging set up
**B)** Requirements are identified and a type chosen
**C)** Unused rules are removed and logs reviewed
**D)** The firewall is moved into production use
**E)** **Rules are checked in a lab against the policy**

**Q135. Which can a firewall NOT stop?**

**A)** Connections to unpublished ports
**B)** Inbound Telnet connections to internal hosts
**C)** **Traffic sent through a user's mobile hotspot**
**D)** Packets carrying spoofed internal source addresses
**E)** Unsolicited inbound TCP connections

**Q136. Which is NOT listed as a firewall limitation?**

**A)** **It cannot filter traffic by port number**
**B)** It cannot stop traffic that bypasses it
**C)** It cannot stop social engineering
**D)** It cannot fully detect hidden malware
**E)** It cannot stop insiders already inside

**Q137. The correct encapsulation order when an application sends data is:**

**A)** Data → packet → segment → frame
**B)** Data → frame → packet → segment
**C)** **Data → segment → packet → frame**
**D)** Segment → data → frame → packet
**E)** Frame → packet → segment → data

**Q138. An off-path attacker:**

**A)** Receives the replies to forged sources
**B)** **Cannot normally see the traffic directly**
**C)** Can always modify traffic in transit
**D)** Must be an insider working in the organization
**E)** Controls the victim's default gateway

**Q139. A compromised insider account lets an external attacker act with internal privileges. This shows that:**

**A)** External attackers can never reach internal systems
**B)** Firewalls fully protect against all insider misuse
**C)** Internal addresses prove a user's real identity
**D)** Insiders are always far more dangerous than outside attackers
**E)** **Network location alone is an incomplete measure of trust**

**Q140. A server becomes slow. According to the lecture, this is:**

**A)** Proof that a SYN flood attack is in progress
**B)** Proof that the firewall rules were bypassed
**C)** Proof that malware is running on the server
**D)** **A symptom, not yet proof of an attack**
**E)** Proof that a MAC flooding attack occurred

**Q141. A port scan discovers a remote administration service. This:**

**A)** Proves that the system was already compromised
**B)** Proves that the service is vulnerable to attack
**C)** Proves that the firewall is misconfigured
**D)** **Shows exposure, not proof of a vulnerability**
**E)** Proves that the scan itself was unauthorized

**Q142. A backup protects recoverability only if it is:**

**A)** Encrypted with the server's own key
**B)** Created after the incident occurred
**C)** Kept online and writable at all times
**D)** Stored on the same primary server
**E)** **Usable and isolated from the incident**

**Q143. A public information page and an examination database:**

**A)** **Both need protection, with different priorities**
**B)** Only the public page needs availability
**C)** Both need exactly identical security restrictions
**D)** Neither needs any integrity controls
**E)** Only the exam database needs any protection

**Q144. Why is the classical Smurf attack less effective today?**

**A)** Firewalls are unable to see any ICMP traffic
**B)** Modern hosts no longer reply to ICMP echo
**C)** **Networks now restrict directed broadcasts**
**D)** ICMP has been removed from the IPv4 suite
**E)** Switches drop every broadcast frame received

**Q145. When setting a port-security MAC limit, the lecture warns that:**

**A)** The limit must always be exactly one MAC address
**B)** **Legitimate devices behind a port must be allowed**
**C)** The limit must equal the size of the DHCP pool
**D)** The limit must match the number of VLANs used
**E)** Port security must be off on user-facing ports

**Q146. Besides CIA, Stallings' wider model (Fig. 1.1) adds:**

**A)** Availability and user anonymity
**B)** Privacy and data possession
**C)** Authorization and non-repudiation
**D)** Utility and control
**E)** **Authenticity and accountability**

**Q147. A laptop is already infected. Does channel encryption alone solve the problem?**

**A)** Yes; encryption removes the malware itself
**B)** No; encryption only works on servers
**C)** **No; data is readable at the infected endpoint**
**D)** Yes; TLS scans each endpoint for malware
**E)** Yes; ciphertext can never be stolen from any device

**Q148. A filter allows only inbound TCP packets with ACK = 1. The effect is:**

**A)** All inbound TCP traffic is blocked completely
**B)** **Outsiders can reply but cannot open connections**
**C)** Only inbound UDP traffic can enter the LAN
**D)** Outsiders can open connections but cannot reply
**E)** All outbound TCP traffic is blocked completely

**Q149. Stateful inspection mainly solves which problem of stateless filters?**

**A)** **ACK spoofing of fake reply packets**
**B)** Inspection of full application data
**C)** Tunneling protocols through ports
**D)** Malware hidden in encrypted traffic
**E)** The need for any rule set at all

**Q150. Which is a limitation of a circuit-level gateway?**

**A)** It cannot hide the internal IP addresses of hosts
**B)** It is slower than an application proxy
**C)** It works only at the data link layer
**D)** **It cannot filter bad content in a session**
**E)** It cannot verify the TCP handshake at all

## Answer Key

1-D 2-E 3-B 4-C 5-A 6-E 7-C 8-A 9-D 10-B
11-C 12-B 13-A 14-E 15-D 16-C 17-A 18-B 19-E 20-D
21-D 22-E 23-A 24-B 25-C 26-C 27-E 28-A 29-D 30-B
31-E 32-A 33-D 34-C 35-B 36-B 37-D 38-A 39-E 40-C
41-D 42-A 43-B 44-E 45-C 46-E 47-D 48-C 49-B 50-A
51-C 52-A 53-B 54-E 55-D 56-D 57-B 58-C 59-E 60-A
61-C 62-E 63-D 64-A 65-B 66-C 67-A 68-B 69-E 70-D
71-E 72-D 73-C 74-A 75-B 76-A 77-D 78-B 79-E 80-C
81-E 82-D 83-C 84-A 85-B 86-A 87-C 88-D 89-B 90-E
91-C 92-E 93-D 94-A 95-B 96-A 97-D 98-E 99-C 100-B
101-B 102-A 103-E 104-D 105-C 106-B 107-D 108-E 109-A 110-C
111-A 112-E 113-B 114-D 115-C 116-A 117-B 118-C 119-D 120-E
121-D 122-E 123-C 124-A 125-B 126-B 127-A 128-C 129-E 130-D
131-B 132-D 133-A 134-E 135-C 136-A 137-C 138-B 139-E 140-D
141-D 142-E 143-A 144-C 145-B 146-E 147-C 148-B 149-A 150-D